Capitolo 9

Sicurezza delle Reti

Nei primi decenni della loro esistenza le reti di calcolatori vennero utilizzate prevalentemente dai ricercatori universitari per inviare e ricevere e-mail e dalle aziende per condividere le stampanti. In quelle applicazioni non si prestava particolare attenzione alla sicurezza. Oggi, milioni di persone usano le reti per fare acquisti, home banking oppure compilare la dichiarazione dei redditi, quindi la sicurezza delle reti sta apparendo all'orizzonte come un problema potenzialmente molto vasto. In questo capitolo studieremo la sicurezza delle reti da diversi punti di vista; indicheremo molti punti critici e discuteremo un gran numero di algoritmi e protocolli che servono a rendere le reti più sicure.La sicurezza è un argomento ampio, che copre una moltitudine di problemi. Nella sua forma più semplice, riguarda come fare in modo che intrusi non riescano a leggere (o, peggio ancora, modi care di nascosto) i messaggi destinati a terzi. Si occupa inoltre di impedire che determinate persone possano accedere a servizi remoti che non sono autorizzate a usare. La sicurezza si occupa anche di come accertarsi dell'identità dei mittenti dei messaggi, di come impedire l'intercettazione e la ripetizione di messaggi legittimi catturati sulla rete e di come perseguire chi a erma di non aver mai spedito certi messaggi.

9.1 Controllo degli Accessi

Il controllo degli accessi è un processo fondamentale che determina "chi può fare cosa a cosa" basandosi su una specifica politica. Questo processo è essenziale per limitare l'accesso a un sistema o alle risorse del sistema in base a criteri che vanno oltre l'identità dell'utente. Adottare una politica di controllo degli accessi porta diversi benefici, come l'attenzione dell'organizzazione su problemi di sicurezza, che può tradursi in un'allocazione più efficiente delle risorse per la sicurezza del sistema. Inoltre, permette di configurare la sicurezza appropriata per ciascuna risorsa del sistema in base al ruolo e all'importanza, facilitando anche le operazioni di auditing e testing del sistema.

I diritti di accesso regolano le autorizzazioni degli utenti per ogni risorsa del sistema. Il controllo degli accessi coinvolge quattro elementi principali: i soggetti (utenti e gruppi di utenti), gli oggetti (file e risorse come memoria, stampanti e scanner), le operazioni e un monitor di riferimento che verifica le regole per concedere l'accesso a un oggetto a un soggetto. Un insieme di regole che specificano le restrizioni è noto come lista di controllo degli accessi (ACL), dove i soggetti sono utenti o gruppi di utenti e gli oggetti sono file e risorse di sistema.

Le modalità di accesso possono essere di due tipi: **osservare** o **alterare**, e ci sono quattro diritti di accesso: **eseguire**, **leggere**, **aggiungere** e **scrivere**. I diritti di accesso possono essere impostati individualmente per ogni risorsa del sistema e per ciascun utente o gruppo, con i diritti degli utenti che prevalgono sempre sui diritti dei gruppi. Il proprietario della risorsa è responsabile della definizione dei diritti di accesso.

Sono state sviluppate diverse tecniche e tecnologie per gestire i diritti di accesso per ogni utente e per ogni oggetto, tra cui matrici di controllo degli accessi, tabelle di capacità, liste di controllo degli accessi, controllo degli accessi basato sui ruoli, controllo degli accessi basato su regole, interfacce limitate e controllo degli accessi dipendente dal contenuto. La matrice di controllo degli accessi organizza tutte le informazioni necessarie per l'amministrazione del controllo degli accessi in una matrice con righe che rappresentano i soggetti o gruppi di soggetti e colonne che rappresentano gli oggetti, mostrando nel corpo

della matrice i permessi dei soggetti sugli oggetti. Le **liste di controllo degli accessi** (*ACL*) memorizzano i gruppi con i diritti di accesso associati agli oggetti, mentre le tabelle di capacità specificano le operazioni che un soggetto può eseguire su un oggetto.

Il concetto di "**AAA**" è il pilastro di qualsiasi disciplina sistematica della sicurezza, composta da **autenticazione**, **autorizzazione** e **contabilità**. L'autenticazione conferma l'identità degli utenti remoti che accedono alla rete, l'autorizzazione assegna diritti differenziati per l'utilizzo di servizi specifici e la contabilità registra tutte le operazioni di un utente durante il processo di servizio di rete per raccogliere informazioni sull'uso delle risorse di rete.

Il processo di autenticazione coinvolge diverse forme di autenticazione, tra cui sistemi biometrici, dispositivi di sicurezza e autenticazione a più livelli. Ad esempio, un utente può inviare il proprio nome utente e password a un server AAA per essere autenticato; se le credenziali sono corrette, il server AAA invierà un messaggio di accettazione, altrimenti invierà un messaggio di rifiuto, bloccando l'accesso alla rete.

9.2 Crittografia

Storicamente quattro gruppi di persone hanno usato e dato il loro contribuito all'arte della crittogra a: i militari, il corpo diplomatico, gli scrittori di diari e gli amanti. Fra tutti questi, i militari hanno avuto il ruolo più importante e hanno dato forma alla disciplina nel corso dei secoli. All'interno delle organizzazioni militari, i messaggi da cifrare erano tradizionalmente assegnati ad addetti di basso livello e bassa paga che avevano il compito di cifrarli e poi trasmetterli. Il notevole volume di messaggi faceva sì che non si potesse usare una squadra di specialisti di alto livello per questo lavoro. Fino all'avvento dei computer, uno dei principali limiti della crittogra a era la capacità degli addetti alla codi ca di riuscire a compiere le operazioni necessarie, spesso anche sul campo di battaglia e utilizzando un equipaggiamento minimo. Un vincolo aggiuntivo era anche la di coltà nel cambiare velocemente da un metodo crittogra co a un altro, in quanto questo signi cava dover formare una gran quantità di persone. Tuttavia, il pericolo che un addetto alla codi capotesse essere catturato dal nemico rendeva essenziale la possibilità di cambiare il metodo crittogra co all'istante, se necessario. Questi requisiti in con itto fra loro hanno dato origine al modello della Figura 8.2.

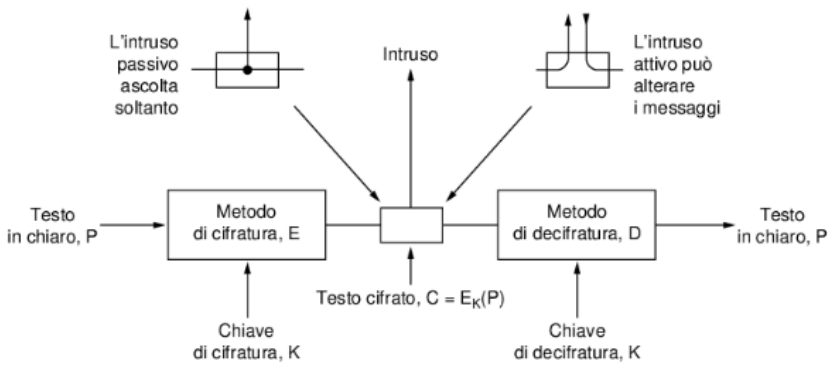

Figura 9.1: Modello di cifratura per un cifrario a chiave simmetrica.

Un messaggio da cifrare, detto **testo in chiaro** (*plaintext*), viene trasformato tramite una funzione parametrizzata da una chiave. L'output del processo di cifratura, noto come **testo cifrato** (*ciphertext*), viene generalmente trasmesso tramite un messaggero o via radio. Assumiamo che il nemico, o intruso, ascolti accuratamente e trascriva completamente il testo cifrato. Al contrario del destinatario legittimo, l'**intruso** non conosce la chiave di decifrazione e quindi non riesce facilmente a decifrare il testo cifrato. In alcuni casi l'intruso, oltre ad ascoltare il canale di comunicazione (intruso passivo), riesce anche a registrare i messaggi per poi ritrasmetterli aggiungendo delle informazioni oppure per modi care i messaggi legittimi prima che raggiungano il destinatario (intruso attivo). L'arte di far saltare (*o rompere, forzare*) i cifrari, chiamata criptoanalisi e l'arte di inventarli (*crittografia*) sono note sotto il nome collettivo di crittologia. Decriptare è l'attività di decifrazione da parte di un criptoanalista (intruso), mentre decifrare è l'operazione legittima di lettura di un messaggio cifrato. È utile avere una notazione per relazionare

fra loro il testo in chiaro, quello cifrato e le chiavi. Useremo la notazione $C = E_K(P)$ per indicare che la cifratura del testo in chiaro P usando la chiave K genera il testo cifrato C. Analogamente, $P = D_K(C)$ indica la decifrazione di C per estrarre il testo in chiaro. Segue quindi che $D_K(E_K(P)) = P$ Questa notazione suggerisce che E e D sono semplicemente delle funzioni matematiche.

Crittografia simmetrica è un metodo di codifica in cui il messaggio originale (plaintext) viene trasformato in un messaggio cifrato (ciphertext) utilizzando una chiave segreta. Per decifrare il ciphertext e ottenere nuovamente il plaintext, è necessaria la stessa chiave utilizzata per la cifratura. Questo metodo non richiede che l'algoritmo di crittografia sia tenuto segreto; l'unica cosa che deve essere mantenuta riservata è la chiave. Questa caratteristica rende la crittografia simmetrica adatta per un uso diffuso.

Crittografia asimmetrica utilizza un sistema di crittografia in cui le operazioni di cifratura e decifratura sono eseguite con chiavi diverse: una chiave pubblica e una chiave privata. La crittografia asimmetrica trasforma il plaintext in ciphertext utilizzando una delle due chiavi e un algoritmo di crittografia. Successivamente, il plaintext può essere recuperato dal ciphertext utilizzando la chiave associata e un algoritmo di decifratura. Questo tipo di crittografia può essere utilizzato per garantire la riservatezza, l'autenticazione o entrambe. Gli algoritmi a chiave pubblica si basano su funzioni matematiche piuttosto che su sostituzioni e permutazioni, rendendo possibile la sicurezza anche quando l'algoritmo è noto pubblicamente.

9.3 Protocolli di Autenticazione

L'**autenticazione** è la tecnica usata dai processi per veri care che la loro controparte nella comunicazione sia veramente chi indica di essere e non un impostore. La veri ca dell'identità di un processo remoto, per combattere gli intrusi attivi e in malafede, è un compito sorprendentemente difficile, che richiede dei protocolli crittografici complessi. In questo paragrafo studieremo alcuni dei molti protocolli di autenticazione usati per le reti insicure. Per inciso, alcune persone confondono l'autorizzazione con l'autenticazione. L'autenticazione riguarda il problema di assicurare l'identità del processo con cui si sta comunicando. L'autorizzazione si occupa, invece, di stabilire che cosa può fare un processo. Per esempio, consideriamo un processo client che contatta un le server e gli comunica: sono il processo di Scott e voglio cancellare il le *ricettario.old*. Il le server ha bisogno delle risposte a queste due domande:

1. la richiesta viene veramente da un processo di Scott (autenticazione)?
2. Scott è autorizzato a cancellare *ricettario.old* (autorizzazione)?

La richiesta può essere evasa soltanto dopo che entrambe le domande hanno ottenuto una risposta certa e affermativa. La prima domanda è quella veramente cruciale. Una volta che il le server sa con chi sta parlando, il controllo dell'autorizzazione consiste solamente in una ricerca dentro tabelle locali o in un database. Per questo motivo, in questo paragrafo ci concentreremo sull'autenticazione.

Un esempio di metodo di autenticazione è l'uso dell'indirizzo IP. Tuttavia, è possibile creare datagrammi IP con indirizzi IP falsi se si ha accesso al kernel del sistema operativo, una tecnica conosciuta come IP spoofing. Un approccio comune per l'autenticazione è l'uso di password, come avviene nei PIN dei dispositivi bancari o nei login dei sistemi operativi. Questo metodo non è completamente sicuro perché un malintenzionato può intercettare la password. Ad esempio, Telnet invia la password in chiaro, quindi se qualcuno monitora la rete locale può rubare le password di login.

Per migliorare la sicurezza, le password possono essere cifrate utilizzando una chiave simmetrica. Questo evita il furto della password ma non risolve completamente il problema dell'autenticazione. Un **attacco di riproduzione** (*playback attack*) può registrare la password cifrata e un malintenzionato può usarla per fingersi un altro utente. Una soluzione è utilizzare una password diversa per ogni autenticazione. Ad esempio, Alice e Bob potrebbero concordare una sequenza di password o un algoritmo di generazione.

Un approccio più generale utilizza un numero univoco chiamato **nonce**, che viene utilizzato una sola volta nel protocollo. Alice invia un messaggio dicendo "Sono Alice". Bob sceglie un nonce R e lo invia ad Alice. Alice quindi cifra il nonce con la sua chiave segreta e lo rimanda a Bob. Se Bob riesce a decifrare il nonce e verificare che è quello che ha inviato, Alice è autenticata.

Un altro metodo utilizza la crittografia a chiave pubblica. Alice invia un messaggio dicendo "Sono Alice". Bob sceglie un nonce e lo invia ad Alice. Alice cifra il nonce con la sua chiave privata e lo invia a Bob. Bob decifra il nonce con la chiave pubblica di Alice e se ottiene il valore corretto, Alice è autenticata. Tuttavia, questo metodo è sicuro quanto il sistema di distribuzione delle chiavi pubbliche, che deve essere affidabile per evitare che un malintenzionato si spacci per Alice.

Tra i vari protocolli di autenticazione, **OAuth2** è noto per essere semplice da implementare e fornire un'autorizzazione lato server del codice, ma è vulnerabile nella gestione di diversi set di codice e può avere seri effetti sui siti connessi a un sistema compromesso. **RADIUS** è un meccanismo efficace per fornire accesso multiplo agli amministratori e assegna un'identità unica a ogni utente in una sessione, ma la sua implementazione iniziale può essere complessa e costosa. SAML riduce i costi amministrativi per gli utenti finali e offre un unico punto di accesso per autenticarsi attraverso vari fornitori di servizi, ma dipende fortemente dal fornitore di identità e gestisce tutti i dati in un unico formato XML.

9.4 Certificati Digitali

Come primo tentativo per distribuire le chiavi pubbliche in modo sicuro, possiamo immaginare l'esistenza di un centro di distribuzione delle chiavi (KDC, *key distribution center*), aperto 24 ore su 24 per fornire le chiavi pubbliche su richiesta. Uno dei problemi associati a questo tipo di soluzione è la mancanza di scalabilità e quindi il fatto che il centro di distribuzione delle chiavi diventerebbe presto il collo di bottiglia del sistema. Inoltre, se questo centro dovesse andare fuori servizio la sicurezza di Internet subirebbe un'improvvisa battuta d'arresto. Per questo motivo è stata sviluppata una soluzione differente, che non richiede un centro di distribuzione delle chiavi on-line a tutte le ore. In effetti non deve essere affatto on-line: quello che deve fare è certi care le chiavi pubbliche che appartengono alle persone, alle aziende e alle altre organizzazioni. Un'organizzazione che certifica le chiavi pubbliche è chiamata una **CA** (*certification authority*, autorità di certficazione). Supponiamo, per esempio, che Bob voglia autorizzare Alice, insieme ad altre persone, a comunicare con lui in modo sicuro. Bob può rivolgersi alla CA portando la sua chiave pubblica e il suo passaporto o un altro documento, e chiedere di essere certi cato. La CA emette un certificato, ne calcola l'hash SHA-1 e lo firma con la chiave privata di CA. Bob paga un compenso alla CA e ottiene un floppy disk con il certificato e l'hash firmato.

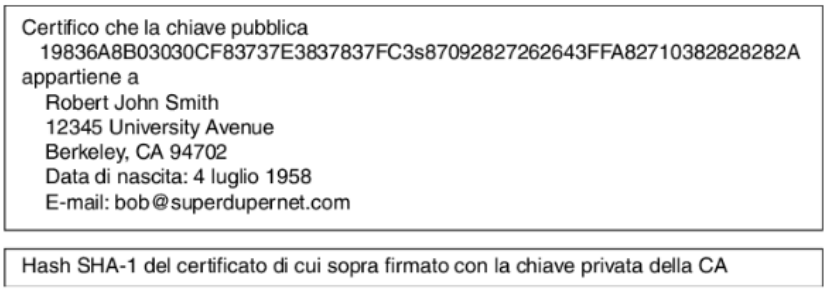

Figura 9.2: Esempio di certificato e del suo hash firmato.